



PHÁP Y SỔ THIẾT BỊ DI ĐỘNG

— TS. Thái Minh Tuấn —
(minhtuan@ctu.edu.vn)

NỘI DUNG

- Tổng quan
- Các thách thức
- Các phương pháp thu thập dữ liệu
- Nguồn bằng chứng số
- Autopsy

Tổng quan

- Thiết bị di động ngày nay không chỉ đơn thuần là công cụ liên lạc
 - Trung tâm lưu trữ dữ liệu cá nhân, phản ánh hành vi, lịch trình và các mối quan hệ xã hội
 - Thông tin liên lạc, tin nhắn, thư điện tử
 - Lịch sử truy cập Internet, vị trí địa lý
 - Các giao dịch ngân hàng
 - Ứng dụng mạng xã hội

Tổng quan

- Pháp y số trên thiết bị di động (Mobile device forensics)
 - Một nhánh của khoa học pháp y số
 - Tập trung vào việc phục hồi, thu thập, lưu trữ, phân tích và trình bày các bằng chứng số được tìm thấy trên các thiết bị di động
- Đóng vai trò quyết định trong các vụ án hình sự, dân sự và hoạt động an ninh mạng

Các thách thức

- Mã hóa dữ liệu mặc định (Default Encryption)
 - Được kích hoạt mặc định trên hầu hết các thiết bị hiện đại
 - Android: File-Based Encryption (FBE)
 - Mỗi tập tin hoặc nhóm tập tin được mã hóa bằng khóa riêng
 - Bảo vệ bởi Trusted Execution Environment (TEE) hoặc phần cứng chuyên dụng
 - iOS: Data Protection
 - Mã hóa toàn bộ dữ liệu bằng các khóa phân cấp phức tạp
 - Không thể đọc hoặc trích xuất khỏi thiết bị
 - Ngay cả khi thu được ảnh vật lý (physical image) của bộ nhớ Flash,
 - Dữ liệu vẫn không đọc được nếu không có khóa giải mã

Các thách thức

- Cơ chế bảo mật phần cứng

- Thành phần bảo mật chuyên dụng nhằm bảo vệ khóa mã hóa và ngăn chặn việc truy cập trái phép vào dữ liệu
- Android: Trusted Execution Environment (TEE), Titan M (Google Pixel), Knox Vault (Samsung)
 - Lưu trữ và quản lý khóa mã hóa
- iPhone: Secure Enclave Processor (SEP)
 - Xử lý xác thực sinh trắc học và bảo vệ khóa mã hóa
 - Hoạt động độc lập với bộ xử lý chính
 - Khiến việc trích xuất khóa gần như không khả thi
- Làm cho các phương pháp JTAG/Chip-off không còn hiệu quả

Các thách thức

- Mã hóa đầu cuối của ứng dụng (End-to-End Encryption)
 - Nhiều ứng dụng nhắn tin hiện nay áp dụng cơ chế mã hóa đầu cuối
 - Dữ liệu lưu trên máy chủ chỉ tồn tại ở dạng mã hóa
 - Chỉ thiết bị của người gửi và người nhận mới có khóa giải mã
 - Phải thu thập dữ liệu trực tiếp từ thiết bị hoặc từ bộ nhớ khi ứng dụng đang hoạt động

Các thách thức

- Cơ chế khóa màn hình và xác thực người dùng
 - Sử dụng nhiều phương thức xác thực như
 - Mã PIN, mật khẩu
 - Hình vẽ (Pattern)
 - Vân tay, khuôn mặt
 - Ngăn chặn truy cập trái phép và bảo vệ khóa mã hóa của hệ thống
 - Sau nhiều lần xác thực sai
 - Tăng thời gian chờ giữa các lần thử
 - Vô hiệu hóa xác thực sinh trắc học
 - Xóa toàn bộ dữ liệu nếu được cấu hình trước
 - Giảm đáng kể khả năng truy cập dữ liệu của điều tra viên khi không có sự hợp tác của chủ sở hữu

Các thách thức

- Secure Boot và Verified Boot

- Android và iOS đều triển khai chuỗi khởi động an toàn (Secure Boot Chain)
 - Android Verified Boot (AVB) và iOS Hardware Root of Trust
 - Kiểm tra tính toàn vẹn của bootloader, kernel và các phân vùng hệ thống
 - Mỗi thành phần chỉ được phép khởi động nếu chữ ký số hợp lệ
- Khởi động hệ điều hành tùy chỉnh hoặc cài đặt môi trường pháp y để thu thập dữ liệu trở nên rất khó khăn

Các thách thức

- Phân mảnh hệ điều hành Android

- Android được sử dụng bởi rất nhiều nhà sản xuất khác nhau
- Samsung - Knox; Xiaomi - HyperOS; Huawei - HarmonyOS
 - Thay đổi giao diện
 - Sửa đổi nhân Linux
 - Bổ sung cơ chế bảo mật riêng
 - Thay đổi cấu trúc lưu trữ
- Phương pháp thu thập dữ liệu có thể hoạt động trên thiết bị này nhưng không áp dụng được cho thiết bị khác

Các thách thức

- Phân mảnh hệ điều hành Android

- Android được sử dụng bởi rất nhiều nhà sản xuất khác nhau
- Samsung - Knox; Xiaomi - HyperOS; Huawei - HarmonyOS
 - Thay đổi giao diện
 - Sửa đổi nhân Linux
 - Bổ sung cơ chế bảo mật riêng
 - Thay đổi cấu trúc lưu trữ
- Phương pháp thu thập dữ liệu có thể hoạt động trên thiết bị này nhưng không áp dụng được cho thiết bị khác

Các thách thức

- Dữ liệu phân tán giữa thiết bị và đám mây
 - Nhiều ứng dụng hiện đại không lưu toàn bộ dữ liệu trên thiết bị
 - Đồng bộ với các dịch vụ đám mây
 - Thách thức trong việc xác định phạm vi bằng chứng và thu thập dữ liệu từ nhiều nguồn khác nhau
 - Các quy định pháp lý liên quan đến quyền riêng tư và truy cập dữ liệu xuyên biên giới

Các thách thức

- Cơ chế chống pháp y (Anti-Forensics)
 - Xóa dữ liệu an toàn (Secure Deletion)
 - Tự động xóa sau nhiều lần nhập sai mật khẩu
 - Phát hiện root hoặc jailbreak
 - Phát hiện thiết bị đang bị gỡ lỗi (Anti-Debugging)
 - Mã hóa cơ sở dữ liệu ứng dụng
 - Tự động xóa tin nhắn sau một khoảng thời gian
 - Tự hủy/xóa dữ liệu từ xa
- Làm mất hoặc làm giảm giá trị của bằng chứng số nếu không được xử lý kịp thời

Các phương pháp thu thập dữ liệu

- Thu thập Logic (Logical Acquisition)

- Nguyên lý:
 - Tương tác với thiết bị thông qua các hàm API của hệ điều hành hoặc giao thức đồng bộ/sao lưu (Backup)
- Cách thực hiện:
 - Sử dụng công cụ sao lưu (ví dụ: adb backup trên Android hoặc qua giao thức iTunes Backup trên iOS)
- Đặc điểm:
 - Chỉ trích xuất được các dữ liệu hiện hành được OS cho phép (Danh bạ, SMS, Call logs, Media công khai)
 - Không thể tiếp cận tập hệ thống bị khóa hoặc dữ liệu đã xóa trong vùng nhớ chưa phân bổ (Unallocated space)

Các phương pháp thu thập dữ liệu

- Thu thập Hệ thống Tập tin (File System Extraction)
 - Nguyên lý:
 - Tiếp cận và sao chép toàn bộ cấu trúc thư mục, tập tin cấu hình, cơ sở dữ liệu ứng dụng nằm trong phân vùng bộ nhớ người dùng
 - Cách thực hiện:
 - Thường yêu cầu quyền truy cập đặc quyền cao (Root trên Android hoặc Jailbreak/Exploit như checkm8 trên iOS)
 - Đặc điểm:
 - Thu thập được toàn bộ cơ sở dữ liệu (SQLite) của các ứng dụng bên thứ ba (Zalo, Telegram, Messenger)

Các phương pháp thu thập dữ liệu

- Thu thập Vật lý (Physical Acquisition)

- Nguyên lý:
 - Sao chép bit-by-bit (Bit-stream image) toàn bộ chip nhớ flash (eMMC/UFS)
- Cách thực hiện:
 - Sử dụng các phương thức phần cứng chuyên dụng (JTAG, Chip-off)
 - Đưa thiết bị vào các chế độ nạp phần mềm cấp thấp của nhà sản xuất
 - Emergency Download Mode - EDL (Qualcomm), MTK Bypass (MediaTek)
- Đặc điểm:
 - Thu thập được toàn bộ (gồm cả phân vùng đã xóa)
 - Tuy nhiên, ảnh đĩa thu được ở dạng vật lý sẽ bị mã hóa hoàn toàn
 - Nếu không lấy được khóa giải mã (Secure Enclave / TEE)

Nguồn bằng chứng số

- Hệ điều hành Android (Android Forensics)
 - Phần lớn dữ liệu người dùng được lưu dưới dạng SQLite Database, XML hoặc các tập tin cấu hình
 - Hầu hết dữ liệu người dùng trên Android được lưu trữ tại phân vùng `/data`
 - Cấu trúc lưu trữ dữ liệu ứng dụng mặc định nằm tại:
`/data/data/<package_name>/`
- Hệ điều hành iOS (iOS Forensics)
 - iOS sử dụng hệ thống tệp tin APFS (Apple File System)
 - Dữ liệu người dùng chủ yếu nằm trong phân vùng `/private/var/mobile/`
- <https://belkasoft.com/mobile-forensics-cheatsheet-system-artifacts>

Nguồn bằng chứng số

- Các bằng chứng số quan trọng cần thu thập
 - Thông tin thiết bị: Số IMEI, Serial Number, IMSI, địa chỉ MAC.
 - Giao tiếp cá nhân: Call logs, SMS/MMS, và đặc biệt là dữ liệu từ các ứng dụng OTT (Zalo, Viber, Telegram, WeChat)
 - Dữ liệu đa phương tiện: Ảnh, Video (phân tích cả siêu dữ liệu EXIF để xác định tọa độ GPS và thời gian chụp)
 - Dữ liệu định vị: Lịch sử kết nối trạm phát sóng (BTS), danh sách các mạng Wi-Fi từng kết nối, dữ liệu định vị từ Google Maps/Apple Maps
 - Dữ liệu hệ thống: Log khởi động, lịch sử cài đặt/gỡ bỏ ứng dụng, mức độ tiêu thụ pin của từng ứng dụng để xác định hành vi người dùng

Autopsy

- Giao diện đồ họa (GUI) cho Sleuth Kit:
 - Đóng vai trò là giao diện người dùng trực quan cho The Sleuth Kit (TSK)
- Phân tích đa nền tảng:
 - Hỗ trợ điều tra chứng cứ từ máy tính (Windows, macOS, Linux), thiết bị di động (Android, iOS), dữ liệu từ thẻ nhớ, USB, ổ đĩa ảo
- Miễn phí và mã nguồn mở:
 - Miễn phí nhưng vẫn cung cấp đầy đủ các tính năng pháp y chuẩn
- Thân thiện với người dùng:
 - Dễ tiếp cận cho cả người mới bắt đầu lẫn các chuyên gia giảng dạy, nghiên cứu

Autopsy

- Trích xuất và phân tích Artifacts:
 - Tự động tìm kiếm và phân loại lịch sử duyệt web, email, cookie, từ khóa tìm kiếm, tài liệu gần đây và các ứng dụng đã cài đặt
- Phân tích dòng thời gian (Timeline Analysis):
 - Sắp xếp toàn bộ sự kiện, tập tin được tạo/chỉnh sửa/truy cập theo mốc thời gian trực quan, giúp điều tra viên nhanh chóng tái dựng lại hành vi của đối tượng
- Phục hồi dữ liệu bị xóa:
 - Khôi phục các tệp tin đã bị xóa từ các vùng nhớ chưa phân bổ (Unallocated space) thông qua cơ chế nhận diện chữ ký tệp (File Carving)

Autopsy - Các tính năng nổi bật

- Phân tích Media & Metadata:
 - Bộ lọc hình ảnh/video thông minh, tự động trích xuất siêu dữ liệu (EXIF) để xác định vị trí địa lý (GPS) và thiết bị chụp
- Hệ thống Module mở rộng (Extensible):
 - Hỗ trợ cài đặt thêm các add-on của bên thứ ba hoặc tự viết module bằng Python/Java để tùy biến khả năng phân tích (ví dụ: phân tích ứng dụng cụ thể)
- Hỗ trợ pháp y số thiết bị di động
 - Không trực tiếp thực hiện việc trích xuất dữ liệu
 - Phân tích các dữ liệu đã thu thập
 - Thông qua ALEAPP và iLEAPP